

中华人民共和国通信行业标准

YD/T 2387—202X
代替 YD/T 2387-2011

网络安全监测系统技术要求

Technical requirements for network security monitor system

(报批稿)

[点击此处添加本稿完成日期]

[××××]-[××]-[××]发布

[××××]-[××]-[××]实施

中华人民共和国工业和信息化部 发布

目 次

前 言III

1 范围1

2 规范性引用文件1

3 术语和定义1

4 网络安全监测系统结构2

5 网络安全监测系统整体功能要求3

6 网络安全监测系统整体性能要求3

 6.1 有效性要求3

 6.2 响应时间要求3

 6.3 资源占用要求3

 6.4 其它要求3

7 网络安全监测系统实现要求4

 7.1 开发配置要求4

 7.2 数据采集技术要求4

 7.3 事件分析与事故响应技术要求4

 7.4 网络态势可视化技术要求6

 7.5 安全告警技术要求6

 7.6 知识库的管理6

8 网络安全监测系统接口要求7

 8.1 内部接口7

 8.2 外部接口7

前 言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

本文件代替YD/T 2387-2011《网络安全监控系统技术要求》，与YD/T 2387-2011相比，除结构调整和编辑性改动之外，主要技术变化如下：

- 更改了功能架构，将“功能架构”改为“系统结构”（见图 1，2011 年版的图 1）；
- 更改了对术语“安全事件”的相关描述（见 3.1，2011 年版的 3.3）
- 增加了对术语“告警”的相关描述（见 3.4）
- 增加了对术语“响应”的相关描述（见 3.5）
- 增加了网络安全监测系统整体功能要求（见 5）
- 删除了与用户维度相关的网络态势展示技术要求（见 2011 年版的 6.3.1）
- 增加了事件分析与事故响应技术要求相关内容（见 7.3）

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由中国通信标准化协会提出并归口。

本文件牵头起草单位：国防科技大学计算机学院、广州大学网络空间先进技术研究院、国家计算机网络应急技术处理协调中心。

本文件参与起草单位：中国信息通信研究院、鹏城实验室、湖南星汉数智科技有限公司、西北工业大学、山东中创软件商用中间件股份有限公司、中国科学院计算技术所、湖南蚁坊软件有限公司、四川亿览态势科技有限公司、恒安嘉新（北京）科技有限公司、北京天融信网络安全技术有限公司、西安邮电大学、上海数据分析与处理技术研究所。

本文件主要起草人：贾 焰、杨 行、李树栋、韩伟红、周 斌、李爱平、张伟哲、王震、江 荣、亓玉璐、赵晓娟、张勇、朱 争、刘海天、谢浩程、钟造成、于 晗、崔婷婷、陈晓光、王龔。

本文件于2011年首次发布，本次为第一次修订。

网络安全监测系统技术要求

1 范围

本文件规定了网络安全监测系统的功能要求、性能要求、技术要求以及接口要求。
本文件适用于计算机网络应急响应组织的网络安全监测系统，也可供其他相关部门参考使用。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

GB/T 28517-2012	网络安全事件描述和交换格式
YD/T 1039.1-2005	900/1800MHz TDMA数字蜂窝移动通信网短消息中心设备技术要求 第一部分： 点对点短消息业务部分
YD/T 2251-2011	国家网络安全应急处理平台安全信息获取接口要求
YD/T 2388-2022	网络脆弱性指数评估方法
YD/T 2389-2022	网络威胁指数评估方法
IETF RFC 2821	简单邮件传输协议

3 术语和定义

下列术语和定义适用于本文件。

3.1

安全事件 security event

计算机信息系统或网络中单一或一系列非预期的，可能损害业务运行和威胁信息安全的信息安全事态。

3.2

安全事故 security incident

计算机信息系统或网络中的硬件、软件、数据因直接或间接攻击事件而遭受非预期的破坏、更改、占用、泄露等现象。

注：安全事故由一个或多个安全事件构成。

3.3

入侵检测 intrusion detection

通过对计算机信息系统或网络中的实时信息进行分析，感知是否存在违反安全策略或被攻击的异常情况发生。

3.4

告警 alert

当管理系统检测到安全事件或由此引发的安全事故后，向相关人员发出的紧急通知。

3.5

响应 response

当管理系统检测到安全事件或由此引发的安全事故后，按照预设向相关人员发出的紧急通知及处理策略，以期保护或恢复资产的后续行为。

4 网络安全监测系统结构

网络安全监测系统主要由数据采集模块、信息仓库、事件分析模块、事故处理模块、安全告警模块和可视化模块6大模块组成，网络安全监测系统结构如图1所示，其各模块功能如下。

- 数据采集模块：按照所建立的指标体系对网络设备状态信息、网络流量信息、日志信息、传感器报警信息等原始数据进行收集存储。
- 信息仓库：包含数据库、知识库和规则库，分别存放采集后的网络安全关键数据，网络威胁指标、系统漏洞指标和基础资产指标等信息，以及网络安全事件的定义和相应响应规则信息。
- 事件分析模块：用于对融合数据进行特征提取和事件层面的关联分析。
- 事故处理模块：用于在网络安全事件层次的基础上发现网络安全事故并生成报告、触发响应、进行态势评估和态势预测。
- 安全告警模块：对网络安全事件分析后产生的重大安全警报进行实时告警。
- 可视化模块：用于对当前安全态势的实时状况以及预测结果展示。

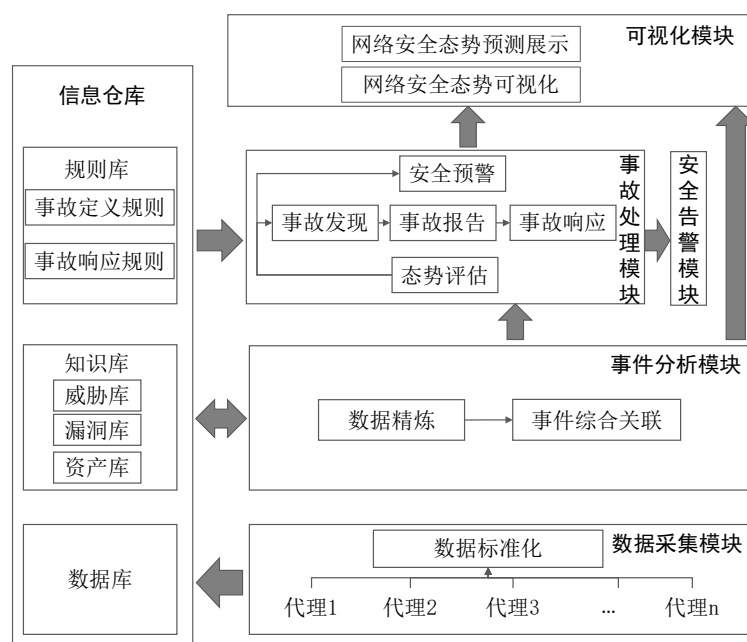


图1 网络安全监测系统结构

5 网络安全监测系统整体功能要求

网络安全监测系统整体功能要求包括：

- a) 捕获安全事件。应能通过部署在网络端的硬件设备和软件程序捕获到具有风险性的网络安全事件，并以统一的格式集中存储事件信息，用于后续分析。
- b) 监测安全状态。应对大规模网络中的网络流量异常、重点服务信息、核心节点状态等进行实时安全监测，以便进行有效风险抑制。
- c) 安全态势评估。应有效整合影响网络安全的脆弱性、威胁性等各类信息，并进行相关性分析，形成评估报告。态势评估涉及当前状态理解和未来趋势预测。
- d) 多维界面展示。应提供从多维度进行查看的网络拓扑结构、网络安全态势、实时事件发生等可视化展示，以满足用户对网络安全态势的直观感知需求。
- e) 协助策略制定。应提供完善的策略可定制管理机制，以符合用户对网络安全监测系统进行级联式的部署配置需要，并提供事故处理策略，支持策略的导入导出。
- f) 激发应急响应。应对所监测网络发生的安全事件进行实时告警，借助多种形式向用户发送告警信息及处理策略。

6 网络安全监测系统整体性能要求

6.1 有效性要求

网络安全监测系统有效性要求包括：

- a) 攻击识别的精准度。主要从漏报率、误报率两个指标来反映网络安全监测系统对网络攻击的识别精准程度，应将两项指标控制在应用许可的范围之内。
- b) 态势评估的正确性。应能通过对信息的转换计算，正确地反映出当前网络的安全状态，从而使得用户能够对当前所监测网络的安全状况有全面准确的了解。
- c) 态势预测的合理性。应能从网络安全历史数据中发掘出变化规律，以此预测将来某时期网络安全状态的较为合理的可能性结果，从而使用户能够对所监测网络的安全状况演变有提前的了解。
- d) 信息发布的指向性。应能根据不同配置设定，实现信息的即时定向发布，将态势信息及事故处置策略投放给管理人员。

6.2 响应时间要求

响应时间是从发现网络安全事件开始，再通过关联分析感知安全事故，最后匹配相应处置策略发送给用户所需要的时间，应满足用户需求，在最大不超过设定阈值的情况下越小越好。（例如：设置最长响应时间为2秒，那么从事件发现记录生成到用户接收告警的时间间隔不能超过2秒）

6.3 资源占用要求

资源占用情况应从网络安全监测系统的CPU占用率、内存占用率和带宽占用率三个方面综合考虑。在同等有效性下，资源占用率越低越好。如，管理员将占用率的阈值分别设置30%，25%，50%，那么在不超过此占用率的情况下数值越低性能越为优化。

6.4 其它要求

网络安全监测系统应具有：

- a) 安全性要求。能够对网络攻击进行防御。
- b) 可靠性要求。能够防范各种失效状况，如单点失效、通信失效等。

7 网络安全监测系统实现要求

7.1 开发配置要求

7.1.1 配置管理

开发者应在开发过程中进行配置管理并满足以下要求：

- a) 开发者应为系统及配置项的不同版本提供唯一的标识；
- b) 开发者应提供配置管理文档，对所有配置项进行标识和描述。

7.1.2 描述性顶层设计

开发者应提供系统的顶层设计并满足以下要求：

- a) 表示应为非形式化；
- b) 按系统描述结构组成及功能实现；
- c) 标识所需的基础性硬件、固件或软件；
- d) 标识子系统的所有接口等。

7.2 数据采集技术要求

7.2.1 系统全面性

数据采集应从以下三个维度综合实施：

- a) 从时间维度来说，数据采集不但应满足网络安全监测系统对实时性的要求，而且应采集到被监测网络每一个时刻的网络安全数据；
- b) 从空间维度来说，针对大规模、国家级的网络，数据采集应采集到关键网络、关键节点、核心设施乃至整个网络的数据；
- c) 从事件维度来说，数据采集应采集到包括流量数据、拓扑数据、服务状态数据、漏洞脆弱性数据以及各种网络攻击威胁数据。

7.2.2 兼容扩展性

兼容扩展性应满足以下三个方面的要求：

- a) 能够集成现有的网络安全产品及其数据；
- b) 数据格式应遵循GB/T 28517-2012中的要求，以统一标准和相同量纲进行转换；
- c) 数据采集应支持多种方式，包括syslog、socket、snmp等采集方式。

7.2.3 集中存储性

数据采集应满足以下要求：

- a) 采用集中式的数据存储方式；
- b) 各采集点向数据存放点发送数据应具备实时性。

7.3 事件分析与事故响应技术要求

7.3.1 数据精炼

应在数据分析前对安全数据进行精炼，包括：

- a) 去重。将相同的事件进行合并。
- b) 过滤。忽略掉不符合给定条件的数据。
- c) 抑制。高级别事件向下涵盖低级别事件。

7.3.2 事故发生

网络安全事故的发现应采取关联分析技术，对不同地点、不同时间、不同层次的网络安全告警进行多维度的关联分析，从而挖掘出真实安全事故，识别真实的安全风险。关联分析至少应完成以下关联：

- a) 事件与资产的关联；
- b) 事件与事件的关联；
- c) 事件与脆弱性的关联。

7.3.3 事故报告

事故报告应能够体现网络安全事故的发生过程，包括：

- a) 网络安全事件的开始时间及持续时间；
- b) 网络安全事件的类型；
- c) 网络安全事件源地址、源端口、目的地址、目的端口；
- d) 所涉及资产的脆弱性状况；
- e) 网络安全事件的关联过程；
- f) 网络安全事故的类型。

7.3.4 事故响应

网络安全监测系统应能够生成事故响应信息并定向发布给特定用户，包括：

- a) 网络安全事故开始的时间；
- b) 网络安全事件的类型、数量；
- c) 网络安全事故涉及范围；
- d) 网络安全事故的处理措施及防护建议。

7.3.5 态势评估

态势评估应对现有的网络脆弱性和遭受威胁进行评估，从而得到被监测网络的整体网络安全态势，应客观、全面地反映被监测网络的真实安全情况。具体要求见YD/T 2388-2022和YD/T 2389-2022。

7.3.6 安全预警

安全预警在网络安全监测系统历史数据的基础上，通过综合分析，对下一步的网络安全态势做出预期判断。安全预警至少应从以下3个粒度进行：

- a) 应支持短期预测（分钟级）；
- b) 应支持中期预测（小时级）；
- c) 应支持长期预测（周级）。

7.4 网络态势可视化技术要求

7.4.1 事件维度

态势可视化应满足用户对不同事件维度的关注需求，支持具体某类或一系列事件的展示，宜覆盖以下7类事件：

- a) 拒绝服务攻击事件；
- b) 木马攻击事件；
- c) 病毒攻击事件；
- d) 蠕虫攻击事件；
- e) 僵尸网络事件；
- f) 网络欺骗事件；
- g) 恶意探测事件。

7.4.2 时间维度

态势可视化应满足用户对不同时间维度的关注需求，具体为：

- a) 应支持不同时间刻度的网络安全态势状况展示；
- b) 应支持不同时间阶段的数据对比；
- c) 应支持不同时间跨度的网络安全态势预测展示。

7.4.3 空间维度

态势可视化应满足用户对不同空间维度的关注需求，支持多种空间层面的展示，具体为：

- a) 地理层面的空间维度（如：国家级、省级、市县级等）；
- b) 物理层面的空间维度（如：大规模网络的核心节点、区域节点、终端节点等）；
- c) 逻辑层面的空间维度（如：数据中心、汇聚节点、接入节点等）。

7.5 安全告警技术要求

安全告警就是对网络安全事件分析后产生的重大安全警报进行实时的告警，应支持以下的几种告警方式：

- a) 通过铃声、指示灯产生报警信号；
- b) 通过电子邮件的方式产生报警信号；
- c) 通过手机短消息的方式产生报警信号。

7.6 知识库的管理

7.6.1 知识库构建要求

网络安全监测系统的知识库是进行网络威胁、网络漏洞等识别的基础，应具备完整性、可靠性等特点。知识库应支持基于专家的修改和自动在线更新功能。应提供接口对现有的一些知识库进行转换。

7.6.2 漏洞库

漏洞库存放标准的漏洞信息，包括漏洞的名称，威胁级别，建议的处置方式等。

漏洞库应支持实时的更新，包括人工更新和网络更新。

漏洞库应支持对现有漏洞库的转换集成。

7.6.3 威胁库

威胁库存放威胁信息，包括威胁的名称、危害性的大小、建议的处置方式等。

8 网络安全监测系统接口要求

8.1 内部接口

8.1.1 数据采集接口

网络安全监测系统应遵循 GB/T 28517-2012 的要求，通过规定的事件描述和交换格式来集成分布式的网络安全检测工具。

数据采集为了满足分布式异构集成技术的要求，应符合一定的接口要求，具体的事件描述格式见表 1。

表1 网络安全事件格式

数据项名称	名称	数据类型	是否必须	说明
Timestamp	时间戳	整型	是	用来标示事件发生的时间
Sensor	探测器	文本	是	用来标示是哪个探测器探测的事件
Dev_type	设备类型	文本	是	用来标示是哪个设备类型
Event_type	事件描述	文本	是	用来对检测到事件进行详细的描述。
Src_ip	源地址	整型	否	检测到威胁发生的源地址
Dst_ip	目的地址	整型	否	检测到威胁发生的目的地址
Src_port	源端口	整型	否	检测到威胁发生的源端口
Dst_port	目的端口	整型	否	检测到威胁发生的目的端口
Priority	优先级	整型	否	该事件的优先级
Reliability	可靠性	整型	否	该事件的可靠性
Risk	危险级别	整型	否	该事件的危险级别
Data	原始信息	文本	否	检测到威胁的原始数据包
注：设备类型参见 YD/T 2251-2011 附录 A.3 设备类型编码方式。				

8.1.2 网络告警接口

网络安全告警的数据接口应按照具体使用者提供的告警接口进行实现。电子邮件接口应符合 IETF RFC 2821, 用于网络安全告警的电子邮件通知。短信息告警应符合 YD/T 1039.1-2005。

8.2 外部接口

为了实现大规模、层次式的网络安全监测，各个网络安全监测系统应支持标准的 IODEF 接口，通过标准接口实现上下级网络安全监测系统之间的数据交换。实现外部接口的要求见 YD/T 2251-2011 中的 9.2 节。